

SDE Hiring Assignments | 2026

Introduction:

This problem statement aims to build an automated scanning tool that analyzes public GitLab repositories for a given user or group, identifies potential risks, and presents them in a structured and actionable format. The goal is to help developers and organizations proactively detect and remediate security and configuration issues.

Problem Statement: GitLab Public Repository Risk Scanner

Build a tool that scans all public repositories for a specified GitLab user or group and identifies potential security risks, exposed secrets, and repository misconfigurations.

1. Input

- The user should be able to provide a GitLab username or group name.
- The user should be able to provide public repositories (projects) associated with that account using GitLab APIs.

2. Analysis

The scanner should inspect repositories for at least 3 categories of risks or misconfigurations, including:

- Sensitive files accidentally committed to the repository
Examples: `.env`, `.pem`, `id_rsa`, `config.json`, `secrets.yml`
- Exposed credentials or secrets using regex-based detection
Examples: API keys, tokens, passwords, cloud credentials
- Missing repository metadata
Examples: missing `README.md`, missing `LICENSE`

You may structure the checks as follows:

Category	Example Checks
Sensitive Files	<code>.env</code> , <code>.pem</code> , <code>id_rsa</code> , <code>config.json</code> , <code>secrets.yml</code>
Exposed Secrets	API keys, tokens, passwords detected via regex
Missing Metadata	No <code>README.md</code> or <code>LICENSE</code> file

3. Output / Deliverable

The tool should generate a clear and structured report in CLI table format **OR** as an HTML dashboard.

The report should include:

- Project (Repository) name
- Detected issue(s)
- Severity level (High, Medium, Low)

Example:

Project Name	Issue	Severity
Project1	Sensitive Files	High
Project2	Exposed Secrets	Medium
Project3	Missing Metadata	Low

4. Optional Enhancements

- Build a web dashboard to visualize scan results
- Export reports as JSON or PDF

- Add authentication support for scanning private repositories (via GitLab token)
- Include Swagger/OpenAPI documentation
- Implement unit tests
- Dockerize the application for easy deployment
- Add GitLab CI pipeline to automate scans